Trustless Biometric Authentication Framework using Cancelable Biometrics and Zero-Knowledge Proofs

Pittaya Suteerawut
Department of Computer Engineering, Faculty of Engineering
Kasetsart University (KU)
Bangkok, Thailand
pittaya.sut@ku.th

Kittipol Horapong
Department of Computer Engineering, Faculty of Engineering
Kasetsart University (KU)
Bangkok, Thailand
kittipol.ho@ku.ac.th

***Abstract*— Centralized biometric storage creates significant security risks, since biometric data cannot be changed once compromised. This paper proposes ZKBIOWN, a trustless biometric authentication framework that combines cancelable biometrics with zero-knowledge proofs. The architecture integrates BioHashing for protected template generation, three-party key distribution to avoid single-point key disclosure, and proof-based verification without directly disclosing biometric template information during authentication process. A browser-based prototype shows the practical feasibility of the proposed design.**

Keywords*— *Trustless Biometric Authentication, Cancelable Biometrics, Biometric Template Protection, Zero-Knowledge Proofs, Privacy-Preserving Authentication

I. Introduction

Nowadays, biometric authentication is widely used in many identity proofing services and has become an important factor in modern multi-factor authentication (MFA) systems. Biometrics can strengthen authentication by providing a strong link between a user and their inherent characteristics. Unlike passwords, biometric traits are closely tied to the user and cannot be easily changed once compromised. For this reason, the protection of biometric data has become a critical issue in secure authentication systems.

In common practice, biometric templates are usually stored on the server side for similarity comparison during the identity proofing process. This common design may introduce several security and privacy concerns. Firstly, when biometric templates are stored at rest in a centralized database, the system creates a single point of compromise. Any compromise or breach at this central point may disclose many biometric templates at once. Secondly, when biometric templates are transmitted over a network, they may be intercepted, attacked, or leaked in transit. This conventional architecture leads to several critical limitations. A database breach may permanently disclose biometric data; users may have limited control over their personal biometric data; and organizations must have significant responsibility for protecting sensitive biometric databases as the systems scale.

Although several protection mechanisms have been introduced to improve biometric security and privacy, important challenges still remain. In particular, existing approaches often focus on either biometric template protection or privacy-preserving authentication alone. Some methods can protect the stored biometric template, but they still require trust in the server during the authentication process. Other methods can reduce data disclosure during authentication, but they may not provide revocability and effective template protection at the same time. Thus, it remains challenging to design a biometric authentication framework that simultaneously supports biometric template protection, privacy-preserving authentication, and reliable authentication performance.

In this paper, we propose a trustless biometric authentication framework that combines cancelable biometrics with zero-knowledge proofs. The main objective is to minimize the disclosure of biometric templates both at rest and in transit while still maintaining reliable authentication performance. In the proposed framework, cancelable biometrics are employed to protect biometric templates through revocable and non-invertible transformation, while zero-knowledge proofs are used to enable privacy-preserving authentication without disclosing the biometric data to the server. The main contribution of this work is the design of a trustless biometric authentication framework that integrates biometric template protection and privacy-preserving authentication to reduce reliance on trusted server-side handling in conventional biometric authentication systems.

II. Related Work

A. Biometric Template Protection

Biometric template protection has been addressed both in standards and in research literature. ISO/IEC 24745:2022 [1] provides requirements and recommendations for protecting biometric information in terms of confidentiality, integrity, and renewability/revocability during storage (at rest) and transfer (in transit), together with privacy-aware processing guidance and application-level threat considerations, while ISO/IEC 30136:2018 [2] supports the evaluation of biometric template protection schemes in terms of accuracy, secrecy, privacy, attack success probability, information leakage, diversity, and unlinkability. These standards establish an important foundation for discussing biometric template protection from both the protection perspective and the evaluation perspective.

In the research literature, biometric template protection approaches can be grouped into biometric cryptosystems and transform-based schemes. In biometric cryptosystems, fuzzy vault [3] protects a secret by combining genuine feature points

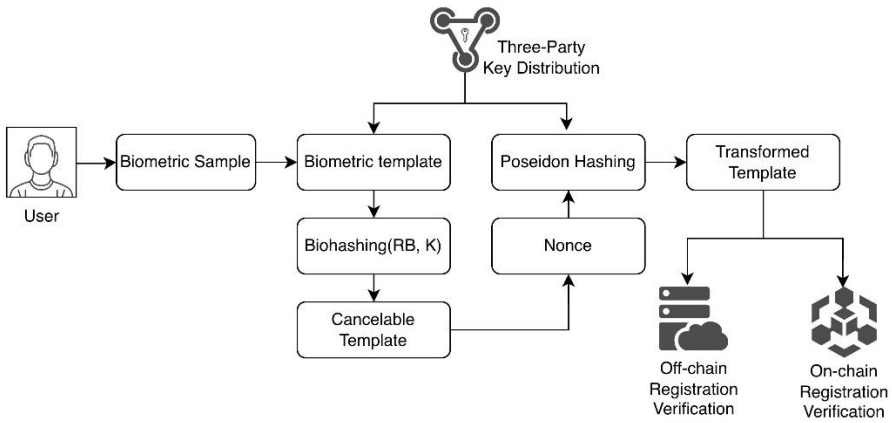

Fig. 1. The Proposed Architecture of Trustless Biometric Authentication Framework.

with chaff points and allows recovery only when the query sufficiently overlaps with the enrolled set, while secure sketch [4] uses public helper data to support consistent reconstruction from a sufficiently similar biometric sample. In transform-based schemes, cancelable biometrics [5] protects templates through revocable and non-invertible transformations, and BioHashing [6] is a representative method that combines biometric features with external randomness to generate a revocable bitstring template. These approaches provide different forms of biometric template protection. However, by themselves, they do not directly address privacy-preserving biometric authentication in a trustless biometric authentication framework.

B. *Privacy-Preserving Biometric Authentication Using Zero-Knowledge Proofs*

Privacy-preserving biometric authentication has also been studied to reduce information disclosure during the authentication process. In particular, zero-knowledge proofs (ZKPs) allow a prover to convince a verifier of the validity of a statement without revealing the underlying secret itself. In the biometric authentication, this property can support authentication without directly revealing the underlying biometric secret to the verifier or server. To make this idea practical, efficient zero-knowledge proof systems are required. Groth's construction [7] has provided a practical foundation for modern zk-SNARK systems with short, constant-size proofs.

Several studies have applied this idea to biometric authentication. Tran *et al.* [8] proposed a privacy-preserving biometric authentication system with binary classification in a zero-knowledge proof protocol. Later, Mao *et al.* [9] presented a privacy-preserving biometric authentication scheme based on Euclidean-distance zero-knowledge proof concepts, in which the protected biometric representation remain encrypted during authentication and is not directly accessible to the verifier. More recently, Guo *et al.* [10] introduced an SVM- and ZKP-based biometric authentication scheme that allows users to authenticate without directly disclosing biometric template information to the verifier or server. These studies show that ZKP-based approaches can reduce information disclosure during authentication. However, they mainly focus on privacy-preserving proof at the authentication stage rather than revocable biometric template protection itself.

III. Proposed Solution

A. *Design Principles*

The proposed framework, called ZKBIOWN, is designed to support trustless biometric authentication by reducing reliance on trusted server-side handling of biometric templates. Instead of storing a raw biometric sample or a directly usable biometric template, the framework stores only a protected commitment derived from a cancelable biometric representation. As shown in Fig. 1, the proposed design combines three main ideas: three-party key distribution, cancelable biometrics, and zero-knowledge-proof-based verification.

The design is based on four principles. The first principle is zero storage of raw biometric data. No raw biometric sample or directly usable biometric template is stored on the server side. The second principle is user-controlled revocation. Biometric protection is performed on the client side through a cancelable transformation, so that the protected representation can be renewed if the key material is changed. The third principle is distributed key control. The key material is distributed across independent parties to reduce the risk of compromise at a single point. The fourth principle is client-side computation. Authentication is completed by proof verification rather than by directly disclosing the biometric template to the verifier. Under this design, the server handles only protected commitment and proof of validity, while the biometric processing remains on the user side.

B. *Three-Party Key Distribution*

The proposed framework uses a three-party key distribution mechanism to derive the transformation key used in biometric template protection. As illustrated in Fig. 2, the key material is distributed across three independent entities: the product service, the user, and the ZKBIOWN platform. These entities contribute the product partial key, the ZKBIOWN partial key, and the user partial key, respectively. In addition, a credential version parameter is included to support credential revocation and re-issuance when the user wants to invalidate a previous credential while continuing to use the same service.

The transformation key is derived in (1) as

$$K = \mathrm{SHA256}(K_p \parallel K_z \parallel K_u \parallel v) \quad (1)$$

where K_p, K_z, and K_u denote the product, ZKBIOWN, and user partial key, respectively, v denotes the credential version, and $\parallel$ denotes concatenation. Under this design, no single entity holds the full transformation key. The inclusion of v supports credential revocation by allowing the same user to generate a new key and a new protected template for the same service context. Therefore, the mechanism supports distributed trust, revocability, and service-specific isolation.

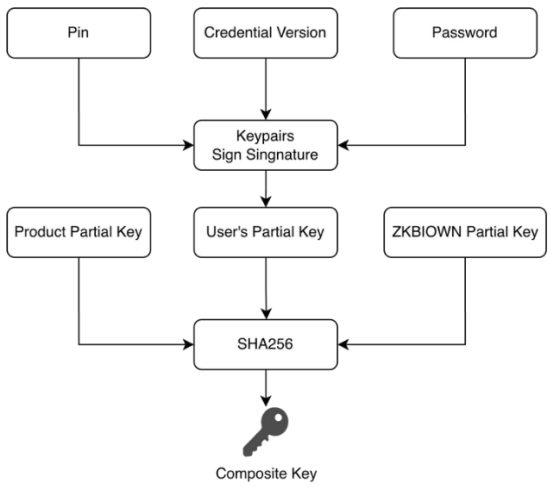

Fig. 2. Three-Party Key Distribution for Composite Key Derivation.

C. Enrollment Phase

After the composite key has been established, the enrollment phase begins on the client side. First, the user captures a biometric sample. However, in practical biometric deployments, liveness detection may also be applied as an additional biometric security measure before feature extraction to reduce presentation attack risk. Then, the captured sample is converted into a biometric template. Next, BioHashing is applied to this biometric template using the composite key derived in the previous step, producing a cancelable biometric template. To protect this transformed representation for future authentication, the client computes a commitment using Poseidon hash [11]. In the proposed framework, only the commitment is registered for later verification, while the raw biometric sample and the directly usable biometric template are not stored on the server side. Depending on the deployment setting, the commitment can be stored either in an off-chain backend or in an on-chain contract. In this way, the enrollment phase establishes a protected biometric reference without disclosing the original biometric template.

D. Authentication and Zero-Knowledge Verification

During authentication, the user first requests access to the requested service. The client then acquires a newly captured biometric sample, performs liveness detection, and extracts a new biometric template. Using the same composite key derived from the three-party key distribution mechanism, the client re-generates the corresponding cancelable biometric template. Instead of sending this template directly, the client generates a zero-knowledge proof showing that the current authentication input is valid with respect to the previously registered commitment. Therefore, the verifier checks only the proof and the required public inputs, while the biometric processing remains on the client side.

The same verification principle can be used in both off-chain and on-chain settings. In the off-chain mode, the backend verifies the proof against the stored commitment. In the on-chain mode, the proof is verified by a smart contract, and the service checks the corresponding authorization result. Under this design, authentication is completed without direct server-side handling of raw biometric data or a directly usable biometric template.

IV. Evaluation

A. Security and Design Properties

The proposed framework is evaluated from both the security and implementation perspectives. At the biometric template protection level, the framework is designed to preserve the main properties of the BioHashing-based cancelable transformation, namely revocability, non-invertibility, and unlinkability under different key settings. At the system level, the framework further reduces direct server-side exposure by storing only a protected commitment instead of a raw biometric sample or a directly usable biometric template.

Table I provides a qualitative comparison of the proposed framework against several representative threats. The comparison is intended to summarize the expected design-level resistance of the architecture rather than to claim a formal security proof. As shown in the table, the framework limits the impact of database compromise to commitment exposure, improves replay resistance through nonce- and proof-dependent verification, reduces cross-service linking through service-specific key derivation, and avoids direct disclosure of a usable biometric template during authentication.

TABLE I. QUALITATIVE ATTACK RESISTANCE COMPARISON

Attack Type	Conventional	ZKBIOWN
Database breach	Full biometric disclosure	Commitment disclosure only
Replay attack	Vulnerable	Mitigated by nonce and proof context
Cross-service linking	Possible	Mitigated by service-specific key derivation
Biometric exposure during authentication	Verifier receives biometric data	Verifier receives proof only

B. Testing Prototype and Performance

To examine the practical feasibility of the proposed framework, we implemented a browser-based prototype using face biometrics as the biometric modality for testing. In this prototype, the captured face image is first processed by RetinaFace [12] for face detection, and the resulting face region is converted into a face embedding that serves as the biometric template for the subsequent protected transformation. The current implementation evaluates several face embedding

models, including FaceNet [13], ArcFace [14], and Face-api.js [15]. These embedding pipelines are then integrated with BioHashing [16], Poseidon hashing [17], and a browser-based ZK proof system [18].

The prototype evaluation was conducted on the FaceScrub [19] dataset, which contains face images collected under unconstrained conditions. After quality filtering, 437 subjects and approximately 2,138 images were retained.

Table II reports the measured runtime overhead on an Apple M4 Pro for both biometric template transformation and zero-knowledge-proof-related operations. The results show that BioHashing and Poseidon hashing require much less time than proof generation, which remains the main computational bottleneck in the current browser-based prototype. Proof verification is also considerably lower, indicating that most of the practical overhead occurs on the client side. Overall, the results support the practical feasibility of the proposed framework, although proof generation still dominates the authentication latency.

TABLE II. PROTOTYPE RUNTIME OVERHEAD

Operation	***Time***	***Implementation Detail***
BioHashing(128D)	46.9ms ± 5.5ms	-
BioHashing(512D)	187.6ms ± 3.8ms	-
Poseidon Hashing	46.9ms ± 3.8ms	-
Proof Genreation	~15s	Browser, WASM
Proof Verification	~4s	Browser, Verifier

Besides runtime feasibility, the proposed framework must also preserve useful biometric discriminability after the protected transformation. Table III shows the similarity scores before and after transformation for same-person and different-person pairs under the same key setting. For all evaluated models, the post-transformation similarity of same-person pairs remains higher than that of different-person pairs, indicating that the protected representation still preserves discriminative information for authentication. Face-api.js gives the highest same-person similarity after transformation, but it also shows the highest different-person similarity, suggesting a smaller class separation than the other models. The different-key cases are not shown here because they resulted in zero similarity under different key settings.

TABLE III. SIMILARITY SCORE BEFORE AND AFTER TRANSFORMATION

Embedding Model	***Before Transformation***	***After Transformation***	
		Same Person	***Different Person***
FaceNet-128	63.94% ± 21.04%	72.86% ± 8.80%	52.40% ± 5.88%
FaceNet-512	62.43% ± 20.69%	72.31% ± 9.06%	51.20% ± 6.62%
ArcFace	55.07% ± 22.79%	69.42% ± 9.68%	51.69% ± 5.96%
Face-api.js	95.28% ± 1.92%	90.59% ± 3.05%	81.31% ± 3.49%

V. CONCLUSION

This paper presented a trustless biometric authentication framework that combines BioHashing, three-party key distribution, and zero-knowledge-proof-based verification for biometric template protection and privacy-preserving authentication. The proposed design stores only a protected commitment and avoids direct server-side handling of raw biometric samples and directly usable biometric templates. A browser-based prototype and evaluation results suggest that the framework is practically feasible and can preserve useful biometric discriminability while supporting revocability.

REFERENCES

[1] ISO/IEC 24745:2022, *Information security, cybersecurity and privacy protection—Biometric information protection*, ISO/IEC, 2022.

[2] ISO/IEC 30136:2018, *Information technology—Performance testing of biometric template protection schemes*, ISO/IEC, 2018.

[3] A. Juels and M. Sudan, “A Fuzzy Vault Scheme”, in *Proc. of IEEE Intl. Symp. on Information Theory (ISIT)*, pp.408, 2002.

[4] Y. Sutcu, Q. Li, and N. Memon, “Protecting biometric templates with sketch: Theory and practice,” *IEEE Transactions on Information Forensics and Security,* vol. 2, no. 3, pp. 503–512, 2007.

[5] V. M. Patel, N. K. Ratha, and R. Chellappa, "Cancelable biometrics: A review," *IEEE Signal Processing Magazine*, vol.32(5), pp.54-65, 2015.

[6] A.B.J. Teoh, A. Goh, and D.C.L. Ngo, “Random Multispace Quantization as an Analytic Mechanism for BioHashing of Biometric and Random Identity Inputs,” *IEEE Trans. Pattern Anal. Mach. Intell.*, vol. 28, no. 12 pp. 1892–1901, 2006.

[7] J. Groth, “On the Size of Pairing-Based Non-interactive Arguments,” in *Advances in Cryptology–EUROCRYPT 2016*, Lecture Notes in Computer Science, vol. 9666, pp. 305–326, 2016.

[8] Q. N. Tran, B. P. Turnbull, M. Wang, and J. Hu, “A Privacy-Preserving Biometric Authentication System with Binary Classification in a Zero Knowledge Proof Protocol,” *IEEE Open Journal of the Computer Society*, vol. 3, pp. 1–10, 2022.

[9] X. Mao, Y. Chen, C. Deng, and X. Zhou, “A novel privacy-preserving biometric authentication scheme,” *PLOS ONE*, vol.18(5), pp.1–19,2023.

[10] C. Guo, L. You, X. Li, G. Hu, S. Wang, and C. Cao, “A novel biometric authentication scheme with privacy protection based on SVM and ZKP,” *Computers & Security*, vol. 144, pp. 1–12, 2024.

[11] L. Grassi, D. Khovratovich, C. Rechberger, A. Roy, and M. Schofnegger, “Poseidon: A New Hash Function for Zero-Knowledge Proof Systems,” in *Proc. of 30th USENIX Security Symp. (USENIX Security 21)*, pp. 519–535, 2021.

[12] S. I. Serengil, "retinaface: RetinaFace Face Detection for Python", 2024. [Online]. Available: https://github.com/serengil/retinaface

[13] D. Sandberg, "FaceNet: TensorFlow implementation of the FaceNet face recognizer", 2024. [Online]. Available: https://github.com/davidsandberg/facenet

[14] J. Deng, J. Guo, N. Xue, S. Zafeiriou, "ArcFace: Additive Angular Margin Loss for Deep Face Recognition", in Proc. of the IEEE Int. Conf. on Computer Vis. and Pattern Recog. (CVPR), pp. 4690-4699, 2019.

[15] V. Mühler, "face-api.js: JavaScript API for Face Recognition in the Browser with tensorflow.js", 2024. [Online]. Available: https://github.com/justadudewhohacks/face-api.js

[16] A. Juels and M. Sudan, "A fuzzy vault scheme," Designs, Codes and Cryptography, vol. 38, no. 2, pp. 237-257, 2006.

[17] C. Hudson, "poseidon-lite: Lightweight JavaScript implementation of Poseidon hash", 2024. [Online]. Available: https://github.com/chancehudson/poseidon-lite

[18] A. B. J. Teoh and C. T. Yuang, "Cancelable biometrics realization with multispace random projections," IEEE Trans. Syst., Man, Cybern. B, vol. 37, no. 5, pp. 1096-1106, 2007.

[19] H. Ng, S. Winkler, "FaceScrub Dataset", 2014. [Online]. Available: https://malea.winkler.site/facescrub.html